

LESSON GUIDE

Technology Plus

Unit 7: Security

6.1.6 – AAA Authorization

Lesson Overview:

In this lesson, students will explore authorization and how it determines what a user can do after they have gained access to an account or system through authentication.

Students will:

- Explain what authorization is and why it is important for digital security.
- Differentiate between administrator and user accounts.
- Describe the least privilege model and how it keeps systems safe.
- Apply authorization concepts to real-world scenarios.

Guiding Question: How does a computer know what I am allowed to do once I log in?

Suggested Grade Levels: 8-12

Technology Needed: No

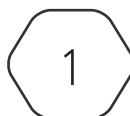
Approximate Time Required: 50-75 minutes

Standards:

CompTIA Tech+ FC0-U71 Objective

- 6.1 - Explain fundamental security concepts and frameworks.
 - Authentication, authorization, accounting, and non-repudiation concepts
 - Authentication
 - Single factor
 - Multifactor
 - Single sign-on
 - **Authorization**
 - **Permissions**
 - **Administrator vs. user accounts**
 - **Least privilege model**
 - Accounting
 - Logs
 - Location tracking
 - Web browser history

This content is based upon work supported by the US Department of Homeland Security's Cybersecurity & Infrastructure Security Agency under the Cybersecurity Education Training and Assistance Program (CETAP).



CYBER.ORG
THE ACADEMIC INITIATIVE OF THE CYBER INNOVATION CENTER

Copyright © 2025 Cyber Innovation Center
All Rights Reserved. Not for Distribution.

Lesson Background

Background Information:

This lesson introduces students to the second A in the AAA security triad: Authorization. While authentication verifies who a user is, authorization determines what that user is allowed to do once they are logged in. Understanding authorization is essential for protecting data, systems, and users from both accidental mistakes and intentional misuse.

Students will first explore the idea of permissions, the specific actions a user can or cannot perform, such as reading, writing, executing, or deleting files. These permissions are the building blocks of authorization and directly influence how roles like administrators, teachers, students, and guests interact with a system. By comparing administrator accounts (with broad access) and user accounts (with limited access), students see why most users do not need full control.

The lesson also highlights the least privilege model, a best practice in cybersecurity that ensures users only receive the minimum permissions needed to perform their tasks. This reduces risks and keeps systems more secure.

By the end of the lesson, students will be able to explain authorization in their own words, identify different permission types, analyze real-world scenarios, and evaluate why access restrictions are an important part of cybersecurity.

Materials Needed:

Materials per Class	• Lesson Guide • Lesson Slides 6.1.6 – AAA Authorization • Activity Slides 6.1.6 – Permission Patrol
Materials per Student	• Student Notes 6.1.6 – AAA Authorization • Student Handout 6.1.6 – AAA Authorization • Assessment 6.1.6 – AAA Authorization (optional)

Lesson Background

Cyber Terms:

Term	Definition
AAA Triad	a cybersecurity framework that secures access to systems and data by making sure users are who they say they are (Authentication), can only do what they're allowed to do (Authorization), and that their actions are recorded (Accounting)
authorization	the process of deciding what an authenticated user can and cannot do, based on their role and permissions in a system
permissions	rules that define what a user can or cannot do with files, folders, or system resources
administrator accounts	accounts with elevated privileges allowing them to manage system settings, install software, and access all files and resources
user accounts	accounts with limited permissions restricted to accessing and managing their own data or specific applications
least privilege model	a rule that dictates that users should be granted the minimal level of access necessary to perform their job functions

6.1.6 – AAA Authorization

Guiding Question: How does a computer know what I am allowed to do once I log in?

Lesson Launch (10 minutes)

- **Ask:** Have you ever tried to open a file or app and received the message ‘Permission Denied’?
- **Say:** This is authorization at work. Even if you successfully log in (authentication), the system still checks whether you are allowed to do certain actions.
- A student may enter a classroom (authentication) but cannot open the teacher’s grade book (authorization).
- Remind students of the AAA Triad and tell them that today, they will learn about the second A – **authorization** which decides what you can do once you prove who you are.

Permissions in Action (25-30 minutes)

- Distribute the Student Handout 6.1.6 – AAA Authorization and have students fill in the answers during the lesson.
- Discuss **authorization**, its definition, and features.
 - For example, after a student is logged into a school system, they may have the authorization to view their own grades but not change them. On the other hand, a teacher is authorized to view and update grades.
 - Authorization:
 - Protects Sensitive Information: Keeps users from seeing or changing data they shouldn’t
 - Supports Different Roles: Ensures each person only has the level of access they need
 - Prevents Mistakes or Misuse: Reduces the chance of unauthorized changes or accidental damage
 - Increases Accountability: Actions can be traced back to authorized users
 - Authorization makes sure that even after someone proves who they are, they can only do what their role allows.
- Introduce the four access control methods and share an example of each.
 - Mandatory Access Control (MAC): Access controlled by a central authority or system, not by the user.
 - Users cannot change permissions.
 - Example: Documents are labeled as Confidential, Secret, or Top Secret. Only people with the right clearance level can read the documents. If you don’t have the right clearance the system

won't let you in.

- Discretionary Access Control (DAC): The owner of the data decides who can access it.
 - Users have more freedom to share or restrict files.
 - Example: If you create a document, you choose who can view, comment, or edit it.
- Role-Based Access Control (RBAC): Permissions are based on a person's role in the organization.
 - Users get access automatically depending on their role.
 - Example: Students, teachers, and principals each have different levels of access in a school system.
- Rule-Based Access Control (Rule-Based RBAC): Access is controlled by a set of rules made by the system.
 - These rules can change depending on conditions like time, location, or actions.
 - Example: A student can log in to a school computer only during school hours; login attempts after hours are denied.
- Discuss **permissions**, its definition, its types, and an example of each type.
 - Permissions are categorized into read, write, execute, and delete.
 - Permission Types:
 - Read: A user or group can view or read a file.
 - A student can open a document but cannot modify it.
 - Write: A user or group can modify a file.
 - A teacher can view and change student's grades in a gradebook.
 - Execute: A user or group can run a program or script from a file.
 - Only certain users can run administrative tools or install software.
 - Delete: A user or group of users can remove a file or folder completely.
 - An administrator can delete outdated student records from a system, but a regular user cannot.
- Discuss role-based permissions and share example roles.
 - Role-based permissions assign permissions based on a user's role in a system rather than individually for each person.
 - Role-Based Permissions:
 - Simplifies Management: You don't need to assign permissions to each individual.
 - Increases Security: Users only get the permissions they need for their role.
 - Supports Least Privilege Principle: Reduces the risk of accidental or malicious access.
 - Example Roles:
 - Principal: Full access to everything

- Teacher: Can read, write, and sometimes execute, but not delete certain files
- Student: Mostly read access, can only write in certain areas
- Guest: Very limited access, read-only
- Discuss the difference between **administrator** and **user accounts**, share an example of each.
 - Administrator: School IT staff who can install software, delete old files, or create new student accounts are administrators.
 - User: A student who can log in, complete assignments, and save files in their folder, but cannot change system settings or access other student files, have a user account.
 - Share the Administrator vs. User Table
 - Administrative accounts are powerful and have full control over a system. User accounts have limited access, with enough to do everyday tasks but not change critical system settings.
- Introduce the **least privilege model** and share how it relates to user accounts

Activity: Permission Patrol (15-20 minutes)

- Display Activity Slides 6.1.6 – Permission Patrol, have students record their answers in the handout.
- Decide if students will work independently or in small groups.
- Read each scenario aloud (or allow students/groups to read independently).
- Students will determine what if access has been granted or denied and briefly explain why.
- Allow time for students to write their answers.

Scenarios and Answers

- A student logs into the school system and wants to view their homework assignment.
Access granted, students have read access to class resources.
- A student tries to change another student's grade in the gradebook.
Access denied, students cannot change any grades, only files they have uploaded.
- A teacher opens the gradebook to update a student's test scores.
Access granted, teachers have write access to grades.
- A guest logs into a school computer and tries to install new software.
Access denied, guests do not have install permissions.
- A principal deletes outdated student records from the system.
Access granted, principals have delete permissions for all files.
- A teacher attempts to change the network settings on the school computer.
Access denied, teachers do not have permission to change system-wide settings.
- A student submits their own homework to the class folder.

Access granted, students have write access for their own files.

- A guest tries to read the school's online newsletter.

Access granted, guests can read public information.

- A principal creates a new teacher account in the system.

Access granted, principals can manage accounts.

- A student attempts to run a system update on the school computer.

Access denied, students do not have execute permissions.

Putting It All Together (5-10 minutes)

Discussion Questions

- Review what students learned today but discussing the questions below as a class.
- What is authorization and what does it do?

Authorization is the process of determining what an authenticated user is allowed to do. It involves setting and enforcing permissions based on the user's identity and role. It protects sensitive information, supports different roles, prevents mistakes or misuse, and increases accountability.

- How do permissions impact authorization?

Permissions define what actions a user or group can perform... They keep users from doing things outside their role or job duties.

- What are the key differences between administrator accounts and user accounts?

Administrator accounts have elevated privileges allowing them to manage system settings, install software, and access all files and resources. User accounts have limited permissions restricted to accessing and managing their own data or specific applications.

- What is the least privilege model and how does it keep systems safe?

The least privilege model is a rule that dictates that users should be granted the minimal level of access necessary to perform their job functions. It reduces the risk of security breaches or accidental misuse by limiting access so users can only do what is necessary for their role, reducing opportunities for mistakes or misuse.